

III. KHUNG KIẾN TRÚC LẠI ĐỀ XUẤT CHO GIAO DỊCH ĐIỆN TỬ AN TOÀN

A. Thiết kế trúc kiến trúc phần mềm tổng quát

Khung kiến trúc lại đề xuất vận hành độc lập với hạ tầng mạng số cái bên dưới, chia tách hệ thống thành 4 lớp chức năng chuyên biệt:

- 1) Lớp Giao diện (Client Layer): Ứng dụng Web (ReactJS / Next.js) và ứng dụng di động native (React Native) tương tác người dùng thời gian thực [21].
- 2) Lớp Nghiệp vụ (Application Service Layer): Engine trung tâm NestJS hoặc Node.js chịu trách nhiệm mã hóa dữ liệu, băm bảo mật mật mã và phân phối lệnh gọi giao dịch đến mạng lưới [19].
- 3) Lớp Dữ liệu ngoài chuỗi (Off-chain Storage Layer): Hệ quản trị dữ liệu quan hệ hoặc NoSQL chịu trách nhiệm lưu trữ thông tin cấu trúc động [20].
- 4) Lớp Sổ cái mật mã (On-chain Ledger Layer): Các nút mạng và Hợp đồng thông minh lưu giữ vĩnh viễn trạng thái sổ của chứng từ giao dịch điện tử [6].

Sơ đồ khối cấu trúc trúc phần mềm tổng quát được minh họa trong Hình 1.

Để đảm bảo tính độc lập cấu trúc, lớp Nghiệp vụ trung tâm ứng dụng mô hình trừu tượng hóa dữ liệu thông qua một cấu trúc điều phối đồng công việc (Workflow Orchestrator Engine). Khi một yêu cầu ký kết hoặc cấp phát được gửi lên từ lớp Giao diện, hệ thống backend không tương tác trực tiếp với tầng sổ cái mật mã, mà thông qua một module dịch đổi trạng thái dữ liệu (State Translation Module). Module này có nhiệm vụ bóc tách các trường thông tin nhạy cảm của người dùng để đóng gói lưu trữ off-chain vào hệ cơ sở dữ liệu quan hệ hoặc NoSQL theo mô hình mã hóa AES-256 bảo mật. Đồng thời, nó tiến hành băm toán học toàn bộ nội dung bản ghi thông tin giao dịch bằng thuật toán mật mã SHA-256 hoặc Keccak-256 để sinh ra một chuỗi định danh duy nhất. Chuỗi định danh băm này chính là phần dữ liệu lõi được đẩy vào các hàm thực thi của Hợp đồng thông minh on-chain. Cơ chế phân tầng nghiêm ngặt này không chỉ bảo vệ quyền riêng tư dữ liệu cá nhân theo các tiêu chuẩn hành chính số [22], mà còn giúp hệ thống đạt được khả năng độc lập nền tảng, cho phép lập trình viên hoán đổi các giải pháp công nghệ ở tầng lưu trữ bên dưới mà không cần tái cấu trúc lại mã nguồn điều phối ở các lớp ứng dụng phía trên.

B. Phân tích an ninh mạng và Mô hình hiểm họa STRIDE

Việc phân tích an ninh mạng đối với một hệ thống lai đòi hỏi phải thiết lập ranh giới tin cậy (trust boundary) chặt chẽ giữa vùng dữ liệu off-chain vận hành thương mại và vùng on-chain bảo chứng pháp lý. Quá trình thực thi logic của Chaincode không chỉ quản lý trạng thái tính mà còn điều phối toàn bộ vòng đời động của thực thể hợp đồng điện tử [6]. Do đó, mô hình STRIDE được áp dụng nhằm nhận diện các hiểm họa tấn công bề mặt trực diện vào hệ thống, đảm bảo tính toàn vẹn dữ liệu và tuân thủ nghiêm ngặt các hành lang pháp lý của Việt Nam về an toàn thông tin mạng cũng như bảo vệ dữ liệu cá nhân của người dùng cuối trong hệ sinh thái số [22].

- **Spoofing (Giả mạo danh tính):** Kẻ tấn công có thể cố gắng giả mạo các tác nhân hợp lệ để thực thi giao dịch trái phép. Hệ thống giảm thiểu nguy cơ này bằng cách

áp dụng giao thức Google OAuth2 ở tầng ứng dụng, kết hợp với cấu trúc định danh MSP (Membership Service Provider) của Hyperledger Fabric [6]. Giải pháp eKYC nghiêm ngặt của VNPT SmartCA ngăn chặn hoàn toàn việc giả mạo chữ ký số pháp lý [6].

- **Tampering (Sửa đổi dữ liệu trái phép):** Mọi hành vi cố tình thay đổi điều khoản hợp đồng hay lịch sử tài chính đều bị vô hiệu hóa bởi cơ chế đồng thuận phân tán của sổ cái bất biến Hyperledger Fabric [6]. Logic Chaincode kiểm soát chặt chẽ các bước chuyển trạng thái, đảm bảo dữ liệu không thể bị can thiệp đơn phương.
- **Repudiation (Chối bỏ trách nhiệm):** Cơ chế ký số kép (Dual Digital Signing Mechanism) ràng buộc trách nhiệm pháp lý không thể chối bỏ của các bên. Chữ ký điện tử được chứng thực qua VNPT SmartCA mang lại giá trị pháp lý tương đương chữ ký tay theo luật định [8], [9].
- **Information Disclosure (Rò rỉ thông tin nhạy cảm):** Kiến trúc cấp quyền của Hyperledger Fabric giới hạn quyền truy cập sổ cái thông qua các kênh bảo mật (Channels) riêng tư [6]. Toàn bộ thông tin truyền tải trên đường truyền đều được mã hóa bằng giao thức TLS 1.2+.
- **Denial of Service (Từ chối dịch vụ - DoS):** Nhằm bảo vệ hệ thống trước các cuộc tấn công làm cạn kiệt tài nguyên mạng, NestJS backend được cấu hình các bộ lọc giới hạn tần suất (Rate Limiting). Hạ tầng được triển khai trên các dịch vụ đám mây co giãn linh hoạt tích hợp sẵn các lớp phòng vệ DDoS tiêu chuẩn.
- **Elevation of Privilege (Leo thang đặc quyền):** Nguy cơ chiếm quyền quản trị được kiểm soát bằng việc áp dụng mô hình phân quyền dựa trên vai trò (RBAC) tại tầng backend và mô hình kiểm soát truy cập dựa trên thuộc tính (ABAC) trực tiếp bên trong mã nguồn Chaincode.

C. Quy trình Thuật toán Điều phối Giao dịch

Để hiện thực hóa khả năng tương thích đa nền tảng và bảo toàn tính toàn vẹn của chứng từ điện tử, khung kiến trúc thiết lập hai quy trình thuật toán tuần tự cốt lõi nhằm điều phối dòng dữ liệu giữa các lớp off-chain và on-chain:

1) *Thuật toán 1: Quy trình Ký số kép và Xác khóa Hợp đồng lai (Case Study 1):* Quy trình thực thi luồng công việc của phân hệ mạng cấp quyền diễn ra khép kín qua các bước logic tuần tự sau:

- 1) *Khởi tạo (Off-chain):* Bên ứng dụng Client gửi yêu cầu tạo lập hợp đồng. API Server (NestJS) tiếp nhận, tính toán mã băm SHA-256 nội dung của tài liệu gốc, lưu trữ biểu mẫu PDF vào AWS S3 và ghi nhận bản ghi tạm thời vào cơ sở dữ liệu PostgreSQL.
- 2) *Kích hoạt Chữ ký số:* Backend phát tín hiệu đồng thời đến hệ thống khóa công cộng VNPT SmartCA của người dùng cuối thông qua kết nối API bảo mật để lấy chữ ký số công cộng được chứng thực, đồng thời kích hoạt chứng thư số Self-CA nội bộ để đóng dấu niêm phong dữ liệu.
- 3) *Cam kết Chuỗi khối (On-chain):* Sau khi nhận đủ cặp khóa chữ ký hợp lệ, dữ liệu định danh hợp đồng cùng chữ ký số được chuyển đổi thành một transaction proposal gửi đến các nút xác thực (Endorsing Peers) của Hyperledger Fabric để kiểm tra và ký chấp thuận thông qua Chaincode.